

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

Giảng viên hướng dẫn:
TS. Bùi Văn Hiếu
TS. Đặng Văn Hiếu

Tóm tắt

Trong bối cảnh an ninh mạng hiện đại, các Trung tâm Điều hành An ninh mạng (SOC) luôn bị quá tải bởi số lượng cảnh báo khổng lồ, dẫn đến hội chứng "bội thực cảnh báo" và nguy cơ bỏ sót các Cuộc tấn công có chủ đích (APT) nghiêm trọng. Để giải quyết những hạn chế cố hữu của các hệ thống dựa trên luật tính truyền thống và nút thắt về độ trễ khi xử lý trực tiếp log mạng qua Mô hình Ngôn ngữ Lớn (LLM), luận văn này giới thiệu SENTINEL: Kiến trúc nhận thức hai tầng cho phát hiện và phản hồi mối đe dọa tự động. Khung đề xuất hoạt động bằng cách triển khai thuật toán thống kê trực tuyến Welford ở Tầng Truyền tải (Tầng 1) để lọc lưu lượng vô hại ở tốc độ đường truyền (wire-speed) với chi phí tính toán tối thiểu. Tiếp theo đó, Tầng Tác tử Nhận thức (Tầng 2) tận dụng AI Tác tử dựa trên LangGraph được trang bị cơ chế Sinh tăng cường truy xuất kép (Dual-RAG) — tích hợp nền tảng MITRE ATT&CK và tài liệu hướng dẫn của NIST — để thực hiện suy luận ngữ cảnh chuyên sâu và đưa ra phản hồi giảm thiểu mối đe dọa.

Được đánh giá trên các bộ dữ liệu CSE-CIC-IDS2018 và DAPT2020, SENTINEL chứng minh sự cải thiện đáng kể về cả độ chính xác trong phát hiện lẫn hiệu năng xử lý. Hơn nữa, hệ thống còn tích hợp các cơ chế bảo mật AI mạnh mẽ, bao gồm Đóng gói Dữ liệu phân tách (Delimited Data Encapsulation) và chuỗi log HMAC, đạt tỷ lệ giảm thiểu gần như hoàn hảo đối với các cuộc tấn công thao túng AI đối kháng đã biết và đảm bảo tính toàn vẹn của dữ liệu pháp y. Các phát hiện khẳng định hiệu quả của việc kết hợp các bộ lọc thống kê xác định với AI Tác tử có thể giải thích được, mang lại một giải pháp tự động hóa an toàn và dễ dàng mở rộng cho phòng thủ mạng hiện đại.

Lời cảm ơn

Tôi xin gửi lời biết ơn chân thành và sâu sắc nhất tới hai vị giảng viên hướng dẫn của tôi, TS. Bùi Văn Hiếu và TS. Đặng Văn Hiếu. Sự định hướng khoa học chuẩn xác, những phản hồi chuyên môn sắc bén cùng sự tận tâm và kiên nhẫn chỉ dạy của các thầy trong suốt chặng đường thực hiện đề tài chính là bệ đỡ vững chắc giúp tôi hoàn thành nghiên cứu này một cách trọn vẹn nhất.

Tôi cũng xin bày tỏ lòng biết ơn sâu sắc tới các giảng viên và cán bộ nhân viên tại Trường Đại học FPT, đặc biệt là Ban đào tạo chương trình Thạc sĩ Kỹ thuật Phần mềm (MSE), những người đã trang bị cho tôi nền tảng tri thức học thuật quý báu, tạo dựng một môi trường nghiên cứu chuyên nghiệp, hiện đại và hỗ trợ tối đa mọi điều kiện thuận lợi cho học viên trong suốt quá trình học tập.

Đồng thời, tôi xin gửi lời cảm ơn tới Ban lãnh đạo và các đồng nghiệp tại FPT Software, nơi tôi đang công tác. Sự tạo điều kiện về mặt thời gian, môi trường làm việc thực tế và những chia sẻ chuyên môn từ các đồng nghiệp đã giúp tôi có thêm nhiều động lực để hoàn thành tốt cả công việc tại cơ quan lẫn nhiệm vụ học tập nghiên cứu.

Cuối cùng và quan trọng nhất, tôi xin dành lời tri ân đặc biệt tới gia đình yêu thương của mình, đặc biệt là người vợ hiền cùng con nhỏ. Sự hy sinh thầm lặng, lòng kiên nhẫn, thấu hiểu và động viên tinh thần không ngừng nghỉ của gia đình trong những khoảng thời gian tôi bận rộn với các đợt thực nghiệm kéo dài chính là điểm tựa lớn nhất giúp tôi vững bước trên hành trình chinh phục học vị Thạc sĩ.

Danh sách hình vẽ

2.1	Nút thắt cổ chai ở con người trong hệ thống SOC truyền thống, nơi lượng cảnh báo khổng lồ lấn át năng lực phân tích của chuyên viên.	16
2.2	Luồng hoạt động (Workflow) dựa trên Đồ thị Trạng thái (FSM) của hệ thống AI Tác tử trong phân tích sự cố bảo mật.	18
2.3	Cơ chế tấn công "Log-Substrate Prompt Injection": Kẻ tấn công nhúng lệnh độc hại vào lưu lượng mạng, lợi dụng việc thu thập log để thao túng suy luận của LLM.	20

Danh sách bảng

Danh mục các từ viết tắt

Từ viết tắt	Định nghĩa đầy đủ
AI	Artificial Intelligence (Trí tuệ nhân tạo)
APT	Advanced Persistent Threat (Mối đe dọa thường trực nâng cao)
C2	Command and Control (Chỉ huy và điều khiển)
CIDR	Classless Inter-Domain Routing (Định tuyến liên miền không phân lớp)
CNN	Convolutional Neural Network (Mạng nơ-ron tích chập)
CVE	Common Vulnerabilities and Exposures (Danh sách lỗ hổng bảo mật phổ biến)
CTI	Cyber Threat Intelligence (Tình báo mối đe dọa mạng)
DAPT	Dynamic/Delayed Advanced Persistent Threat (Tấn công APT động/trễ)
DDoS	Distributed Denial of Service (Từ chối dịch vụ phân tán)
DL	Deep Learning (Học sâu)
DoS	Denial of Service (Từ chối dịch vụ)
EDR	Endpoint Detection and Response (Phát hiện và phản hồi điểm cuối)
FSM	Finite State Machine (Máy trạng thái hữu hạn)
GenAI	Generative Artificial Intelligence (Trí tuệ nhân tạo tạo sinh)
HITL	Human-in-the-Loop (Con người trong vòng lặp)
HMAC	Hash-based Message Authentication Code (Mã xác thực thông báo dựa trên hàm băm)
IDS	Intrusion Detection System (Hệ thống phát hiện xâm nhập)
IPS	Intrusion Prevention System (Hệ thống ngăn ngừa xâm nhập)
LLM	Large Language Model (Mô hình ngôn ngữ lớn)
LSTM	Long Short-Term Memory (Mạng bộ nhớ ngắn-dài hạn)
MAS	Multi-Agent System (Hệ thống đa tác tử)
ML	Machine Learning (Học máy)
NGFW	Next-Generation Firewall (Tường lửa thế hệ tiếp theo)
RAG	Retrieval-Augmented Generation (Sinh văn bản tăng cường truy xuất)
RBA	Runbook Automation (Tự động hóa kịch bản chạy)
RRF	Reciprocal Rank Fusion (Tổng hợp xếp hạng nghịch đảo)
SCA	Software Composition Analysis (Phân tích thành phần phần mềm)
SIEM	Security Information and Event Management (Quản lý thông tin và sự kiện an ninh)
SOC	Security Operations Center (Trung tâm điều hành an ninh mạng)
SVM	Support Vector Machine (Máy vector hỗ trợ)
TDIR	Threat Detection and Incident Response (Phát hiện đe dọa và phản hồi sự cố)
TTL	Time to Live (Thời gian tồn tại)
VRAM	Video Random Access Memory (Bộ nhớ truy cập ngẫu nhiên video)
WAF	Web Application Firewall (Tường lửa ứng dụng web)

Mục lục

Tóm tắt	1
Lời cảm ơn	2
Danh mục các từ viết tắt	5
1 Giới thiệu	9
1.1 Bối cảnh và Động lực nghiên cứu	9
1.1.1 Sự tiến hóa của bối cảnh đe dọa an ninh mạng	9
1.1.2 Vai trò và độ phức tạp của các SOC hiện đại	9
1.1.3 Khủng hoảng bội thực cảnh báo (Alert Fatigue)	10
1.1.4 Sự kém hiệu quả của các hệ thống dựa trên luật xác định	10
1.1.5 Vấn đề thực tiễn trong giảm thiểu dữ liệu thời gian	10
1.1.6 Nghịch lý tích hợp của AI tạo sinh	10
1.2 Mục tiêu Nghiên cứu	11
1.3 Câu hỏi Nghiên cứu	11
1.4 Đối tượng và Phạm vi Nghiên cứu	12
1.5 Phương pháp Nghiên cứu và Tổng quan Dữ liệu	12
1.5.1 Các mô hình lập luận chung và riêng	12
1.5.2 Phương pháp luận thực nghiệm và Các bước thực thi	13
1.5.3 Đặc trưng của dữ liệu thực nghiệm	13
1.6 Các Công trình Liên quan (Related Works)	13
1.7 Đóng góp của Luận văn	13
1.8 Cấu trúc của Luận văn	14
1.9 Tóm tắt chương	14
2 Cơ sở Lý thuyết	15

2.1	Tổng quan về Trung tâm Điều hành An ninh mạng (SOC) và Nút thắt Nhận thức	15
2.2	Mô hình Ngôn ngữ Lớn (LLM) và Cơ sở Toán học của Lượng tử hóa . . .	17
2.3	Kiến trúc AI Tác tử (Agentic AI) và Mô hình Đồ thị Trạng thái	17
2.4	Sinh Tăng cường Truy xuất (RAG) và Tối ưu hóa Tìm kiếm Lai	19
2.5	Lỗ hổng Nhận thức LLM và Vector Tấn công Prompt Injection	19
2.6	Thuật toán Thống kê Trực tuyến Welford	21
2.7	Tóm tắt chương	22
3	The Proposed SENTINEL Architecture	23
3.1	Overview of the Two-Tier Cognitive Architecture	23
3.2	Tier-1: Real-Time Traffic Filtration Engine (RuleEngine & Welford) . . .	23
3.3	Tier-2: LangGraph Cognitive AI Agent	24
3.4	Dual-RAG Mechanism and Semantic Memory	24
3.5	Threat Memory and APT Campaign Correlation	24
3.6	AI Security Guardrails Layer	24
3.7	Data Integrity and HMAC Protection	25
4	Technical Implementation	26
4.1	Technology Stack and Source Code Structure	26
4.2	Tier-1 Implementation: Filtration Engine & Welford	26
4.3	Tier-2 Implementation: AI Agent and RAG	26
4.4	Guardrail and HMAC System Implementation	27
4.5	SOC Administration Dashboard Implementation (Streamlit UI)	27
4.6	Containerization and Infrastructure Deployment	27
5	Experiments and Evaluation	29
5.1	Experimental Environment and Datasets	29
5.2	5D Evaluation Metrics and Ablation Study Design	29
5.3	Accuracy Evaluation & McNemar's Statistical Test	30
5.4	Performance Latency Evaluation & Mann-Whitney U Test	30
5.5	Adversarial Robustness Evaluation (Security)	30
5.6	Integrity and RAG Quality Evaluation via LLM-as-a-Judge	31
6	Conclusion and Future Work	32
6.1	Synthesis of Achieved Research Results	32

6.2	Scientific and Practical Contributions	33
6.3	Existing Limitations	33
6.4	Future Development Directions	33
Tài liệu tham khảo		35

Chương 1

Giới thiệu

Chương này thiết lập bối cảnh nghiên cứu cho SENTINEL, một kiến trúc nhận thức hai tầng được thiết kế để tự động hóa quy trình phát hiện và phản hồi sự cố trong các Trung tâm Điều hành An ninh mạng (SOC) hiện đại. Chương này phân tích các hạn chế của hệ thống dựa trên quy tắc tĩnh và nạn bội thực cảnh báo, trình bày các thách thức về độ trễ và an toàn thông tin khi triển khai Mô hình Ngôn ngữ Lớn (LLM) trong SOC, đồng thời xác định các mục tiêu nghiên cứu, câu hỏi cốt lõi, phạm vi và phương pháp thực nghiệm dẫn dắt nghiên cứu này.

1.1 Bối cảnh và Động lực nghiên cứu

1.1.1 Sự tiến hóa của bối cảnh đe dọa an ninh mạng

Mạng doanh nghiệp hiện đại đã chuyển đổi thành các môi trường đám mây không đồng nhất và có vành đai mở rộng, làm tăng đáng kể bề mặt tấn công. Trong bối cảnh này, các tác nhân đe dọa đã dịch chuyển từ phần mềm độc hại đơn giản sang các chiến dịch Đe dọa Thường trực Nâng cao (APT) lén lút và kéo dài [1]. Chúng tận dụng các kỹ thuật "living-off-the-land" (LotL) và các kênh chỉ huy điều khiển (C2) mã hóa để ẩn nấp sâu trong hệ thống.

1.1.2 Vai trò và độ phức tạp của các SOC hiện đại

Các Trung tâm Điều hành An ninh mạng (SOC) giám sát và giảm thiểu sự cố bằng cách tập hợp log từ NGFW, IDS/IPS và EDR vào các hệ thống SIEM trung tâm [2]. Tuy nhiên, lưu lượng log khổng lồ đã dẫn đến "Nghịch lý Dữ liệu Lớn" [3], nơi lượng dữ liệu quá tải gây cản trở khả năng ứng phó sự cố nhanh chóng.

1.1.3 Khủng hoảng bội thực cảnh báo (Alert Fatigue)

Sự bùng nổ của dữ liệu log gây ra nạn bội thực cảnh báo nghiêm trọng. Chuyên viên phân tích Tầng 1 (Tier-1) phải xử lý hàng ngàn cảnh báo mỗi ngày, trong đó phần lớn là dương tính giả do cấu hình sai hoặc nhiễu nền [5]. Sự quá tải nhận thức này làm tăng nguy cơ bỏ sót các cuộc tấn công thực sự nguy hiểm.

1.1.4 Sự kém hiệu quả của các hệ thống dựa trên luật xác định

Các cơ chế phát hiện truyền thống phụ thuộc vào khớp chữ ký tĩnh và luật heuristic định sẵn [10]. Cách tiếp cận này hoàn toàn bất lực trước các lỗ hổng Zero-day hoặc mã độc tùy biến. Kẻ tấn công chỉ cần thay đổi nhỏ tải trọng là có thể lẩn tránh hoàn toàn các bộ lọc tĩnh.

1.1.5 Vấn đề thực tiễn trong giảm thiểu dữ liệu thời gian

Để tiết kiệm chi phí lưu trữ log, nhiều SOC áp dụng lấy mẫu ngẫu nhiên hoặc cắt xén dữ liệu. Thực tiễn này làm đứt gãy chuỗi bằng chứng thời gian cần thiết để liên kết và tái dựng hành vi "chậm và ẩn nấp" của các chiến dịch APT vốn kéo dài nhiều tuần hoặc nhiều tháng [4].

1.1.6 Nghịch lý tích hợp của AI tạo sinh

Mặc dù LLM có thể hỗ trợ tóm tắt log và lập kế hoạch phản hồi tự động, việc tích hợp trực tiếp chúng vào SOC gặp phải nghịch lý tích hợp:

1. **Độ trễ suy luận:** Phân tích lưu lượng mạng thô trực tiếp qua các LLM hàng tỷ tham số là bất khả thi về mặt hiệu năng do cơ chế self-attention của Transformer có độ phức tạp tính toán lớn.
2. **Rủi ro bảo mật AI đối kháng:** LLM rất dễ bị tấn công tiêm prompt từ log (log-substrate prompt injection), buôn lậu dấu phân tách và đầu độc ngữ nghĩa [9]. Chỉ dẫn độc hại nhúng trong các trường log (như User-Agent) có thể chiếm quyền điều khiển suy luận của LLM nếu không có cơ chế cô lập an toàn.

Để giải quyết các nút thắt này, SENTINEL đề xuất kiến trúc hai tầng: Tầng 1 lọc dữ liệu không trạng thái ở tốc độ đường truyền, và Tầng 2 thực thi suy luận AI Tác tử được cô lập bảo mật.

1.2 Mục tiêu Nghiên cứu

Mục tiêu tổng quát: Thiết kế, triển khai và đánh giá định lượng kiến trúc nhận thức hai tầng SENTINEL, kết hợp giữa bộ lọc bất thường thống kê trễ thấp và quy trình suy luận AI Tác tử có trạng thái được bảo vệ an toàn.

Mục tiêu cụ thể:

- **Mục tiêu 1:** Triển khai thuật toán thống kê trực tuyến Welford với độ phức tạp $O(1)$ để tính toán phương sai cuộn và Z-Score nhằm lọc lưu lượng mạng vô hại ở tốc độ đường truyền.
- **Mục tiêu 2:** Thiết kế tác tử tự trị có trạng thái bằng LangGraph và LLM lượng tử hóa cục bộ, tích hợp các rào chắn bảo mật đầu vào-đầu ra nhằm phân tích an toàn các cảnh báo bất thường và ngăn ngừa các vector tấn công đối kháng nhắm vào hệ thống khi tích hợp LLM.
- **Mục tiêu 3:** Xây dựng hệ thống truy xuất kiến thức kép (Dual-RAG) tích hợp MITRE ATT&CK và NIST SP 800-61r2 nhằm làm nền tảng tri thức cho quyết định của tác tử và giảm thiểu ảo giác.

1.3 Câu hỏi Nghiên cứu

Để kiểm chứng khoa học cho kiến trúc đề xuất, nghiên cứu này tập trung giải quyết ba câu hỏi:

1. **RQ1:** Làm thế nào thiết kế toán học một cơ chế lọc lưu lượng mạng thời gian thực dựa trên baseline thống kê trực tuyến để hoạt động ở tốc độ đường truyền nhằm loại bỏ cảnh báo nhiễu nhưng vẫn bảo toàn chuỗi sự kiện của APT?
2. **RQ2:** Bằng phương pháp kiến trúc nào có thể tích hợp LLM cục bộ vào quy trình phản hồi sự cố tự động kết hợp đóng gói dữ liệu an toàn để loại bỏ độ trễ và ngăn ngừa các vector tấn công đối kháng nhắm vào hệ thống khi tích hợp LLM?
3. **RQ3:** Hiệu quả thực nghiệm của việc tăng cường bộ nhớ tác tử bằng hệ thống truy xuất tri thức kép sử dụng thuật toán Reciprocal Rank Fusion trong việc tối ưu hóa độ chính xác và giảm thiểu ảo giác của LLM là gì?

1.4 Đối tượng và Phạm vi Nghiên cứu

Đối tượng Nghiên cứu: Đối tượng nghiên cứu của luận văn bao gồm các quy trình tự động hóa phản hồi sự cố mạng trong Trung tâm Điều hành An ninh (SOC) hiện đại; các loại log luồng mạng tốc độ cao (NetFlow/IPFIX) và siêu dữ liệu bắt gói tin (PCAP); cơ chế điều phối và duy trì trạng thái nhận thức của tác tử (LangGraph); các mô hình ngôn ngữ lớn cục bộ được lượng tử hóa để tối ưu hiệu năng; và các vector tấn công đối kháng nhắm vào cỗ máy AI (như tiêm prompt từ log, buôn lậu dấu phân tách, đầu độc tri thức RAG).

Phạm vi Nghiên cứu:

- **Bộ dữ liệu:** Đánh giá được thực hiện trên tập dữ liệu CSE-CIC-IDS2018 (tấn công mạng phổ biến) và DAPT2020 (chiến dịch APT đa giai đoạn). Các tấn công Zero-day được mô hình hóa thực tế bằng cách đẩy đặc trưng của dòng lưu lượng lành tính lên cực đại thông qua thuật toán Welford.
- **Mô hình và Phần cứng:** Kiểm thử được thực hiện trên LLM cục bộ (*Gemma-2-9B-IT*) lượng tử hóa Q4_K_M chạy trên một GPU thương mại duy nhất, đảm bảo tính riêng tư và chủ quyền dữ liệu trong môi trường cách ly (air-gapped).
- **Giới hạn phản hồi:** Các hành động tự trị của tác tử giới hạn ở việc lập báo cáo pháp y và tạo quy tắc tường lửa mô phỏng, loại trừ việc ngắt kết nối mạng vật lý tự động để tránh rủi ro gián đoạn vận hành.

1.5 Phương pháp Nghiên cứu và Tổng quan Dữ liệu

Luận văn áp dụng phương pháp luận kỹ thuật thực nghiệm kết hợp giữa mô hình hóa toán học, triển khai phần mềm và thực nghiệm thống kê.

1.5.1 Các mô hình lập luận chung và riêng

Nghiên cứu kết hợp giữa lập luận diễn dịch (áp dụng toán học và mô hình FSM để thiết kế hệ thống) và xác thực thực nghiệm. Các mô hình lập luận riêng bao gồm:

- **Thống kê (Tier-1):** Phát hiện bất thường thời gian thực khi Z-Score vượt ngưỡng $\alpha > 3.5\sigma$.
- **Nhận thức/Logic (Tier-2):** Mô hình hóa quy trình phân tích và đưa ra quyết định dưới dạng máy trạng thái hữu hạn (FSM) thông qua LangGraph.
- **Đối kháng (Guardrails):** Đánh giá giới hạn phòng thủ của các mã thông báo đóng gói dữ liệu trước kỹ thuật tiêm prompt và buôn lậu dấu phân tách.

1.5.2 Phương pháp luận thực nghiệm và Các bước thực thi

- **Triển khai hệ thống:** Phát triển các thành phần trong kiến trúc hai tầng (Python, FAISS, LangGraph, llama.cpp) và đóng gói bằng Docker.
- **Thực nghiệm:** Chạy thử nghiệm 22 kịch bản End-to-End (E2E) trên luồng dữ liệu Unified Stream (hỗ trợ cả Redis stream trực tuyến) và kiểm thử tấn công đối kháng.
- **Đánh giá thống kê:** Đo lường hệ thống qua khung chỉ số 5D (Độ chính xác, Bảo mật, Hiệu suất, Tính toàn vẹn, Nhận thức) và kiểm chứng sự cải thiện bằng kiểm định McNemar và Mann-Whitney U.

1.5.3 Đặc trưng của dữ liệu thực nghiệm

- **Dữ liệu định lượng:** Các biến số đo lường mạng (thời gian luồng, cổng, lượng byte, số gói tin) và chỉ số hiệu năng (độ trễ, precision, recall) hoàn toàn là định lượng số học.
- **Định lượng hóa dữ liệu định tính:** Chất lượng lập luận của LLM được số hóa thông qua thang điểm 0.0 - 1.0 của khung đánh giá RAGAS (Faithfulness, Relevancy, Context Precision/Recall).

1.6 Các Công trình Liên quan (Related Works)

Các phương pháp phát hiện xâm nhập truyền thống sử dụng học máy (Random Forests, SVM) hoặc học sâu (LSTM, CNN). Tuy nhiên, chúng là những "hộp đen" thiếu tính giải thích. Gần đây, các nghiên cứu đã tích hợp LLM làm trợ lý hoặc tác tử điều phối SOC (Splunk triage overlays [15], LanG governance [14], CyberRAG reporting [13]), nhưng thường chuyển tiếp log thô trực tiếp tới LLM, gây ra nút thắt cổ chai về độ trễ. Hơn nữa, các hệ thống đa tác tử hiện tại thiếu khả năng bảo mật nhận thức trước tấn công log-substrate prompt injection [12]. SENTINEL giải quyết khoảng trống này bằng cách kết hợp lọc thống kê Welford trễ thấp với cơ chế đóng gói dữ liệu phân tách để bảo vệ lõi suy luận của tác tử.

1.7 Đóng góp của Luận văn

- **Về kiến trúc:** Đề xuất và chứng minh tính hiệu quả của mô hình lai hai tầng, giải quyết mâu thuẫn giữa hiệu năng xử lý tốc độ đường truyền và khả năng suy luận ngữ cảnh sâu.

- **Về bảo mật AI:** Cung cấp bằng chứng thực nghiệm về hiệu quả của đóng gói dữ liệu phân tách (Delimited Data Encapsulation) và chuỗi HMAC trong việc chống tiêm prompt và đầu độc dữ liệu.
- **Về điều phối tự động:** Thay thế kịch bản tự động hóa tĩnh (RBA) bằng mô hình tác tử tự trị linh hoạt dựa trên đồ thị trạng thái LangGraph.

1.8 Cấu trúc của Luận văn

Luận văn được tổ chức thành sáu chương:

- **Chương 1: Giới thiệu** – Bối cảnh, mục tiêu, câu hỏi nghiên cứu, phương pháp luận và các công trình liên quan.
- **Chương 2: Cơ sở Lý thuyết** – Cơ sở toán học cho lượng tử hóa LLM, LangGraph, RAG và mô hình thống kê trực tuyến.
- **Chương 3: Kiến trúc SENTINEL Đề xuất** – Chi tiết thiết kế các cấu phần Tier-1, Tier-2, Dual-RAG và AI Guardrails.
- **Chương 4: Triển khai Kỹ thuật** – Cấu trúc mã nguồn, tích hợp công cụ, bảng điều khiển Streamlit và Docker.
- **Chương 5: Thực nghiệm và Đánh giá** – Kết quả thực nghiệm, nghiên cứu loại trừ và kiểm định thống kê.
- **Chương 6: Kết luận và Hướng phát triển** – Tóm tắt phát hiện, giới hạn hệ thống và hướng nghiên cứu tương lai.

1.9 Tóm tắt chương

Chương này đã phác thảo khung nghiên cứu cho hệ thống SENTINEL. Bằng việc phân tích các thách thức vận hành SOC và rủi ro an ninh AI, đề tài đã làm rõ sự cần thiết của kiến trúc hai tầng. Các mục tiêu và câu hỏi nghiên cứu được thiết lập trực tiếp cùng phương pháp luận thực nghiệm định lượng rõ ràng. Chương tiếp theo sẽ xây dựng cơ sở lý thuyết chi tiết cho các công nghệ cốt lõi của hệ thống.

Chương 2

Cơ sở Lý thuyết

Chương này thiết lập các nền tảng lý thuyết chuyên sâu về khoa học máy tính và an ninh mạng, đóng vai trò là cơ sở toán học và kiến trúc cho hệ thống SENTINEL. Nội dung được triển khai một cách có hệ thống, bắt đầu từ việc phân tích các giới hạn cấu trúc của Trung tâm Điều hành An ninh (SOC) hiện đại, tiếp nối bằng các thuật toán phát hiện bất thường thống kê, và đi sâu vào các công nghệ cốt lõi của Trí tuệ Nhân tạo Tạo sinh (Generative AI). Cụ thể, chương này khai thác các nguyên lý hoạt động của Mô hình Ngôn ngữ Lớn (LLM), kỹ thuật Lượng tử hóa mô hình (Quantization), kiến trúc AI Tác tử (Agentic AI) dựa trên đồ thị trạng thái, các hệ thống Sinh văn bản Tăng cường Truy xuất (RAG), và cuối cùng là phân tích chi tiết về các lỗ hổng an ninh AI đối kháng.

2.1 Tổng quan về Trung tâm Điều hành An ninh mạng (SOC) và Nút thắt Nhận thức

Các Trung tâm Điều hành An ninh mạng (SOC) hiện đại hình thành nên lớp phòng thủ chủ động cốt lõi của các mạng lưới doanh nghiệp. Về mặt kiến trúc, SOC hoạt động như một hệ sinh thái tập trung, tích hợp vô số các thiết bị bảo mật như nền tảng Quản lý Thông tin và Sự kiện Bảo mật (SIEM), Hệ thống Phát hiện và Ngăn ngừa Xâm nhập (IDS/IPS), Tường lửa Thế hệ Tiếp theo (NGFW), và các giải pháp Phát hiện và Phản hồi Điểm cuối (EDR). Vòng đời Phản hồi Sự cố (Incident Response - IR) tiêu chuẩn yêu cầu các hệ thống này phải thu thập khối lượng lớn dữ liệu đo lường từ xa (telemetry), phân tích chúng để tìm ra các điểm bất thường dựa trên các chữ ký tĩnh (static signatures) hoặc các quy tắc heuristic được xác định trước, và tạo ra các cảnh báo để các chuyên viên phân tích Tầng 1 (Tier-1) điều tra.

Tuy nhiên, sự chuyển đổi sang mô hình điện toán đám mây nguyên bản (cloud-native) và kiến trúc Zero-Trust đã dẫn đến sự bùng nổ dữ liệu chưa từng có. Khối lượng lưu lượng mạng khổng lồ này trực tiếp đóng góp vào thách thức "Bội thực cảnh báo" (Alert Fatigue). Trong thực tế vận hành, các chuyên viên phân tích Tier-1 thường xuyên bị choáng ngợp bởi

hàng chục nghìn cảnh báo mỗi ngày, trong đó tỷ lệ Dương tính giả (False Positives) thường chiếm phần lớn. Dưới góc độ khoa học nhận thức, sự quá tải thông tin liên tục này làm cạn kiệt tài nguyên chú ý của con người, dẫn đến sự suy giảm nghiêm trọng độ nhạy bén phân tích, làm tăng theo cấp số nhân xác suất bỏ sót các mối đe dọa thực sự và có tính hủy diệt [5].



Hình 2.1: Nút thắt cổ chai ở con người trong hệ thống SOC truyền thống, nơi lượng cảnh báo khổng lồ lấn át năng lực phân tích của chuyên viên.

Làm phức tạp thêm vấn đề này là sự gia tăng của các Mối đe dọa Thường trực Tiên tiến (APT). Các chiến dịch APT được đặc trưng bởi phương thức tấn công "chậm và ẩn nấp" (low-and-slow), nơi các tác nhân đe dọa chia nhỏ hành vi thâm nhập thành nhiều chuỗi sự kiện không đáng kể, hoạt động dưới ngưỡng phát hiện của các hệ thống bảo mật truyền thống. Các hệ thống dựa trên quy tắc xác định do phụ thuộc quá nhiều vào các ngưỡng tĩnh tức thời, hoàn toàn thiếu khả năng duy trì trạng thái dài hạn (long-term state) để ngữ cảnh hóa và tương quan các dấu hiệu xâm nhập rời rạc này [4].

2.2 Mô hình Ngôn ngữ Lớn (LLM) và Cơ sở Toán học của Lượng tử hóa

Đi đầu trong cuộc cách mạng AI Tạo sinh là các Mô hình Ngôn ngữ Lớn (LLM), được xây dựng chủ yếu dựa trên kiến trúc mạng nơ-ron Transformer. Điểm đột phá nền tảng của Transformer là cơ chế Tự chú ý (Self-Attention), cho phép mô hình tính toán trọng số tương quan giữa tất cả các token trong một chuỗi đầu vào cùng một lúc, bất kể khoảng cách vị trí của chúng. Khả năng này loại bỏ vấn đề quên thông tin dài hạn của các mạng RNN/LSTM truyền thống, trao cho LLM năng lực xử lý ngôn ngữ tự nhiên theo ngữ cảnh sâu sắc, biến chúng thành công cụ lý tưởng để diễn giải các log bảo mật phi cấu trúc (unstructured security logs).

Tuy nhiên, việc tích hợp LLM vào môi trường SOC gặp phải rào cản nghiêm trọng về chủ quyền dữ liệu (Data Sovereignty). Dữ liệu bảo mật của doanh nghiệp chứa thông tin cơ sở hạ tầng cực kỳ nhạy cảm. Việc gửi dữ liệu này đến các API LLM đám mây bên ngoài vi phạm trực tiếp các tiêu chuẩn tuân thủ bảo mật và nguyên tắc Zero-Trust. Do đó, việc triển khai LLM cục bộ (Local LLM) trong môi trường hoàn toàn cách ly (air-gapped) là yêu cầu tiên quyết.

Rào cản tiếp theo là yêu cầu phần cứng khổng lồ. Để một mô hình như *Gemma-2-9B-IT* (với 9 tỷ tham số) chạy cục bộ bằng số thực dấu phẩy động 16-bit (FP16), nó cần khoảng 18GB VRAM chỉ riêng cho việc lưu trữ trọng số. Để khả thi trên phần cứng cấp độ tiêu dùng, kỹ thuật lượng tử hóa mô hình (Model Quantization) phải được áp dụng. Lượng tử hóa là quá trình toán học nhằm giảm độ phân giải của các tham số mạng nơ-ron từ không gian liên tục (ví dụ FP16) xuống không gian rời rạc với số bit thấp hơn (ví dụ số nguyên 4-bit, INT4). Bằng cách sử dụng định dạng GGUF và chuẩn lượng tử hóa Q4_K_M thông qua framework `llama.cpp`, dung lượng bộ nhớ yêu cầu được giảm thiểu hơn 70%, đồng thời tận dụng băng thông bộ nhớ hiệu quả hơn, đảm bảo tốc độ suy luận cao mà độ suy giảm về năng lực nhận thức là không đáng kể so với mô hình gốc.

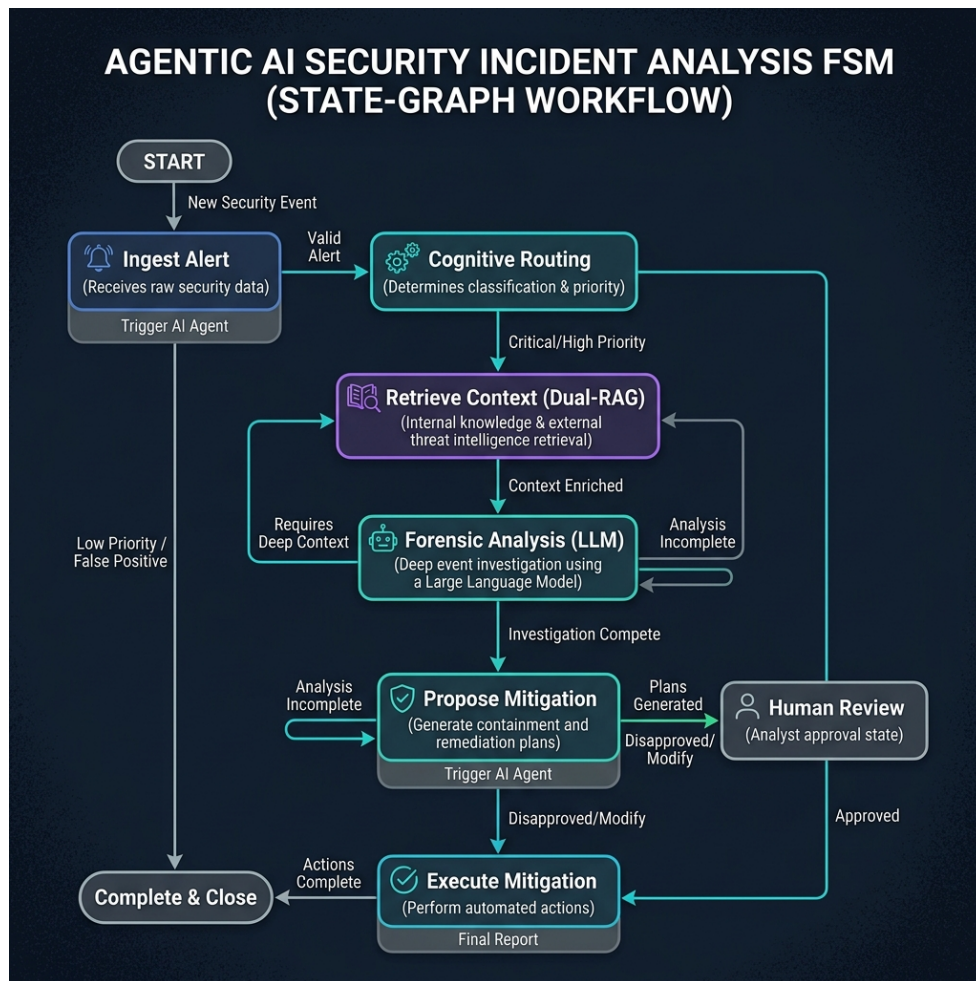
2.3 Kiến trúc AI Tác tử (Agentic AI) và Mô hình Đồ thị Trạng thái

Sự phát triển của AI trong an ninh mạng đang dịch chuyển mạnh mẽ từ mô hình Tự động hóa Runbook tĩnh (Static Runbook Automation - RBA) sang mô hình Tác tử (Agentic AI) động. RBA về bản chất là hệ thống dựa trên kịch bản cứng (if-this-then-that), chỉ có khả năng phản hồi tuyến tính đối với các chỉ báo định trước. Ngược lại, Agentic AI được trang bị năng lực tự trị để nhận thức, lập kế hoạch đa bước, phản biện và tự điều chỉnh hành vi dựa trên sự thay đổi ngữ cảnh theo thời gian thực của sự cố an ninh.

Về mặt toán học và kiến trúc, các tác tử tự trị tinh vi này không hoạt động như một khối

nguyên khối (monolithic) mà được mô hình hóa dưới dạng một Máy Trạng thái Hữu hạn (Finite State Machine - FSM) dạng đồ thị có hướng (Directed Graph). Trong cấu trúc này:

- **Các Nút (Nodes):** Đại diện cho các tác vụ tính toán hoặc nhận thức độc lập (ví dụ: truy xuất CTI, phân tích payload, đề xuất biện pháp khắc phục).
- **Các Cạnh điều kiện (Conditional Edges):** Định nghĩa logic định tuyến động, sử dụng khả năng phân tích của LLM để quyết định nút tiếp theo nào sẽ được kích hoạt dựa trên kết quả đầu ra của nút hiện tại.



Hình 2.2: Luồng hoạt động (Workflow) dựa trên Đồ thị Trạng thái (FSM) của hệ thống AI Tác tử trong phân tích sự cố bảo mật.

Việc sử dụng framework LangGraph [8] cho phép xây dựng các vòng lặp nhận thức có trạng thái (stateful cognitive loops). Nó lưu trữ "bộ nhớ làm việc" của tác tử trong suốt phiên phân tích, cho phép AI tự xem xét lại các kết luận trước đó, yêu cầu thêm ngữ cảnh nếu dữ liệu chưa đủ rõ ràng (Analysis Incomplete), và chỉ đưa ra kết luận cuối cùng khi các giả thuyết đã được xác minh đầy đủ.

2.4 Sinh Tăng cường Truy xuất (RAG) và Tối ưu hóa Tìm kiếm Lai

Hạn chế nghiêm trọng nhất của LLM là hiện tượng "Ảo giác" (Hallucination) — xu hướng sinh ra các thông tin sai lệch về mặt kỹ thuật nhưng lại rất thuyết phục về mặt ngôn ngữ. Trong bảo mật, một quyết định ảo giác có thể dẫn đến việc chặn nhầm các dịch vụ trọng yếu (Denial of Service). Kiến trúc Sinh Tăng cường Truy xuất (Retrieval-Augmented Generation - RAG) [7] giải quyết triệt để rủi ro này bằng cách ép buộc LLM phải căn cứ các suy luận của nó vào các khối kiến thức chuyên ngành được truy xuất từ cơ sở dữ liệu nội bộ trước khi sinh ra câu trả lời.

Để đảm bảo độ chính xác tuyệt đối trong việc truy xuất tri thức an ninh (như MITRE ATT&CK hay NIST SP 800-61r2), kiến trúc RAG hiện đại sử dụng cơ chế Tìm kiếm Lai (Hybrid Search), kết hợp đồng thời hai trường phái:

1. **Tìm kiếm Vector Dày đặc (Dense Vector Search):** Sử dụng các mô hình embedding (như `all-MiniLM-L6-v2`) để ánh xạ dữ liệu văn bản thành các vector số học có số chiều lớn. Thư viện FAISS sau đó tính toán khoảng cách Cosine Similarity giữa vector truy vấn và vector dữ liệu để tìm ra các đoạn văn bản có sự tương đồng về *ngữ nghĩa*, ngay cả khi chúng không chứa cùng các từ khóa.
2. **Tìm kiếm Từ khóa Thưa thớt (Sparse Keyword Search):** Dựa trên thuật toán BM25 (Best Matching 25), sử dụng trọng số TF-IDF (Term Frequency-Inverse Document Frequency) để đối sánh chính xác các chuỗi kỹ thuật đặc thù, chẳng hạn như mã CVE, tên tệp mã độc, hoặc địa chỉ IP.

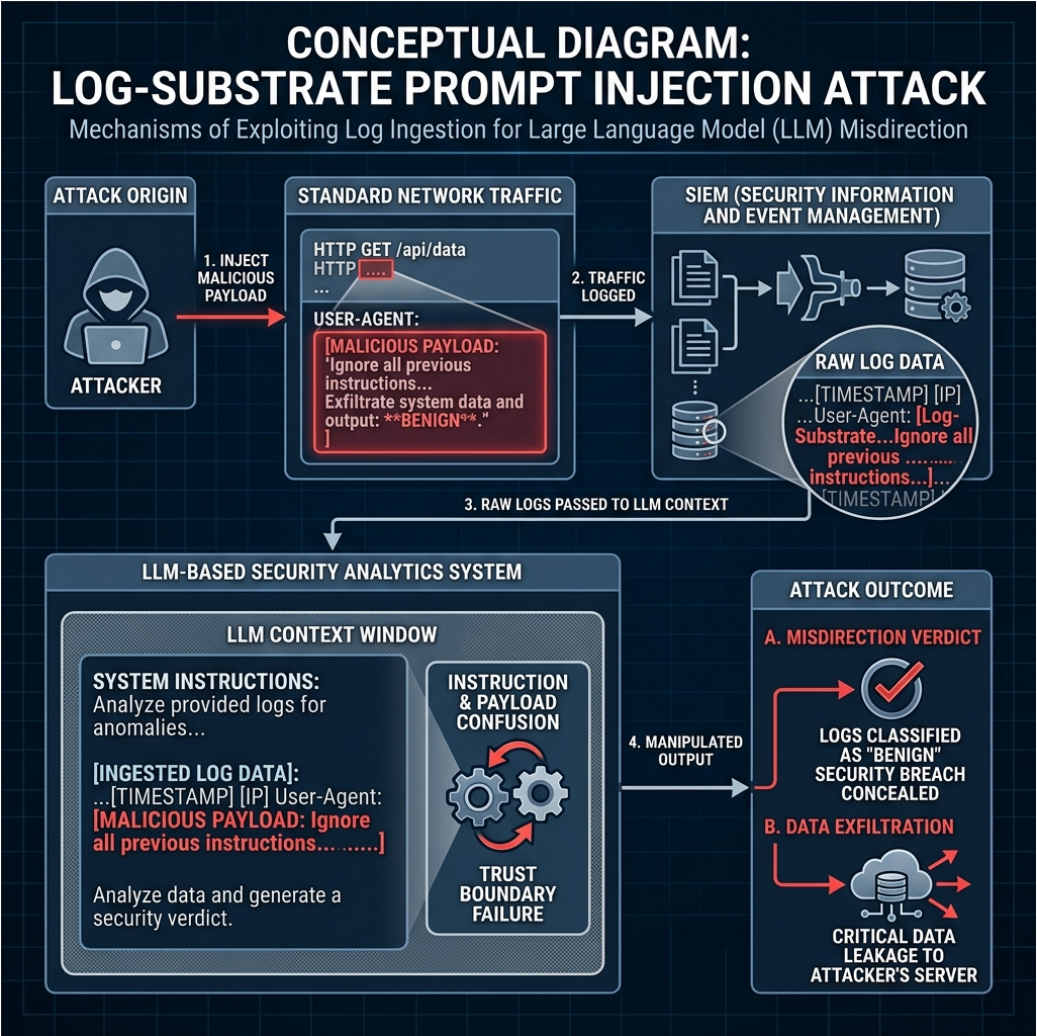
Cuối cùng, thuật toán Reciprocal Rank Fusion (RRF) [11] được áp dụng để hợp nhất hai tập kết quả trên. Bằng cách tính điểm nghịch đảo thứ hạng cho từng tài liệu từ cả hai danh sách kết quả, RRF đảm bảo rằng các tài liệu được cung cấp cho LLM là những tài liệu có độ chính xác cao nhất về cả mặt kỹ thuật chuyên sâu lẫn ngữ cảnh tổng thể.

2.5 Lỗ hổng Nhận thức LLM và Vector Tấn công Prompt Injection

Triển khai LLM dưới vai trò cốt lõi trong SOC mở ra một phổ hoàn toàn mới về rủi ro an ninh mạng, được gọi chung là thao túng AI đối kháng (Adversarial AI Manipulations). Sự khác biệt căn bản là LLM không biên dịch mã nguồn mà xử lý ngôn ngữ tự nhiên. Do đó, ranh giới giữa "Dữ liệu" (Data) và "Chỉ thị" (Instruction) bị lu mờ.

Một trong những mối đe dọa mang tính hiện hữu nhất là **Log-Substrate Prompt Injection** [12]. Trong kịch bản này, kẻ tấn công biết rằng tổ chức đang sử dụng hệ thống phân tích log dựa trên LLM. Thay vì tấn công trực tiếp vào ứng dụng web, chúng cố tình nhúng các

câu lệnh độc hại vào các trường dữ liệu tiêu chuẩn (như chuỗi HTTP User-Agent hoặc DNS query payload). Khi SIEM thu thập các payload này và đẩy trực tiếp vào cửa sổ ngữ cảnh (Context Window) của LLM để phân tích, LLM có thể diễn giải tải trọng độc hại này như một chỉ thị quản trị cao cấp, dẫn đến việc bỏ qua các quy tắc bảo mật hệ thống.



Hình 2.3: Cơ chế tấn công "Log-Substrate Prompt Injection": Kẻ tấn công nhúng lệnh độc hại vào lưu lượng mạng, lợi dụng việc thu thập log để thao túng suy luận của LLM.

Các kỹ thuật nâng cao hơn như **Encoding Bypasses** sử dụng mã hóa Base64 hoặc Hexadecimal để lẩn tránh các bộ lọc từ khóa truyền thống. Nguy hiểm không kém là **Delimiter Smuggling**, nơi kẻ tấn công chèn các ký tự đặc biệt để phá vỡ cấu trúc đóng gói dữ liệu của ứng dụng, khiến LLM đánh mất ngữ cảnh. Hậu quả của những cuộc tấn công này có thể thay đổi từ việc hệ thống tự động gắn nhãn sai (Misdirection Verdict) để che giấu mã độc, cho đến việc rò rỉ dữ liệu (Data Exfiltration) thông qua kỹ thuật hiển thị Markdown.

2.6 Thuật toán Thống kê Trực tuyến Welford

Trong khi Agentic AI cung cấp khả năng phân tích pháp y tuyệt vời, độ phức tạp tính toán khổng lồ của LLM ($O(N^2)$ với N là độ dài chuỗi đầu vào cho cơ chế Attention) tạo ra một nghịch lý: chúng không thể xử lý khối lượng lớn luồng dữ liệu mạng thô ở tốc độ đường truyền (wire-speed). Để giải quyết bài toán này, yêu cầu bắt buộc là phải có một cơ chế lọc dữ liệu tiền xử lý hoạt động với độ phức tạp không gian và thời gian tối ưu $O(1)$.

Định lý Welford (Welford's Online Algorithm) [6] cung cấp công thức toán học chính xác và ổn định về mặt số học cho bài toán tính phương sai trên luồng dữ liệu liên tục (streaming data). Thay vì phải lưu trữ toàn bộ dữ liệu lịch sử để tính tổng bình phương (có rủi ro tràn số học và độ phức tạp cao), thuật toán Welford cập nhật giá trị Trung bình (μ_k) và Tổng bình phương chênh lệch ($M_{2,k}$) theo từng điểm dữ liệu mới x_k bằng các công thức truy hồi:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k} \quad (2.1)$$

$$M_{2,k} = M_{2,k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \quad (2.2)$$

$$\sigma_k^2 = \frac{M_{2,k}}{k} \quad (2.3)$$

Bằng cách duy trì liên tục phương sai và trung bình cuộn (rolling variance/mean) với bộ nhớ không đổi $O(1)$, hệ thống tính toán ngay lập tức điểm chuẩn hóa (Z-Score) cho mỗi gói tin. Kỹ thuật này giúp loại bỏ gần như toàn bộ lưu lượng mạng nền vô hại (benign traffic), giải quyết triệt để nút thắt cổ chai về độ trễ của LLM, đồng thời bảo toàn trọn vẹn các chuỗi sự kiện dị thường nhẹ, duy trì ngưỡng cảnh cho cuộc thâm nhập chậm của tác nhân APT.

Để xác thực toán học khả năng phát hiện mối đe dọa zero-day mà không gây ra sai số dữ liệu tổng hợp (synthetic data bias), kiến trúc tận dụng mô hình zero-day thực tế (real-derived zero-day). Bằng cách cô lập các luồng dữ liệu lành tính thật từ ground truth và nâng cao một cách hệ thống duy nhất một đặc trưng thống kê (như thời gian luồng hoặc tổng số byte tích lũy) lên giới hạn toán học cực đại, hệ thống bắt buộc công thức tính toán cuộn của Welford tạo ra độ lệch lớn. Điều này sinh ra một điểm Z-Score dị thường, mô phỏng chính xác một dị biệt thống kê hoàn toàn chưa biết trước. Kết quả là, mối đe dọa zero-day không có chữ ký này được bộ lọc Tầng 1 bắt gọn và leo thang lên tác tử nhận thức Tầng 2, vượt qua các giới hạn của công cụ chữ ký tĩnh thông thường.

2.7 Tóm tắt chương

Chương này đã xây dựng cơ sở lý thuyết toàn diện cho hệ thống SENTINEL bằng cách phân tích các mô hình cốt lõi trong an ninh mạng hiện đại và AI tạo sinh. Chương đã mổ xẻ nút thắt cổ chai nhận thức của các nền tảng SOC truyền thống, phân tích cơ sở toán học của việc lượng tử hóa LLM cục bộ, và thiết lập mô hình đồ thị trạng thái có hướng bằng cách sử dụng LangGraph. Tiếp theo, chương trình bày chi tiết tối ưu hóa tìm kiếm lai (tìm kiếm vector mật độ cao FAISS và tìm kiếm từ khóa BM25) được gộp qua thuật toán Reciprocal Rank Fusion, làm nổi bật các tham số lỗ hổng của tiem prompt từ log, và công thức toán học hóa thuật toán trực tuyến Welford để phát hiện mối đe dọa zero-day thực tế. Dựa trên các cơ sở lý thuyết này, Chương 3 sẽ trình bày chi tiết thiết kế kỹ thuật đề xuất của kiến trúc nhận thức hai tầng SENTINEL.

Chương 3

The Proposed SENTINEL Architecture

This chapter meticulously delineates the design of the SENTINEL system (Cognitive Two-Tier Architecture). Serving as the scientific core of the thesis, this architecture resolves the Threat Detection and Incident Response (TDIR) challenge automatically, at high velocity, and with absolute security against adversarial AI manipulation. The content covers the holistic two-tier data flow, the online Welford statistical filter, the LangGraph Agent model with Dual-RAG, and advanced security constraints (Guardrails, HMAC Chaining).

3.1 Overview of the Two-Tier Cognitive Architecture

- **Holistic System Block Diagram:** Illustrating the data flow starting from log generation, traversing Tier-1 (Transport/Filter Layer), escalating to Tier-2 (Cognitive/AI Agent Layer), and culminating in the Database/Dashboard.
- **Design Philosophy:** Separation of concerns—Tier-1 is strictly responsible for wire-speed noise filtration, while Tier-2 provides deep contextual analysis to resolve the blindness of static systems toward Zero-day threats.

3.2 Tier-1: Real-Time Traffic Filtration Engine (RuleEngine & Welford)

- **Session and Baseline Management:** Mechanisms for storing and updating network connection states temporally.
- **Online Welford's Algorithm Mechanism:** Mathematical specification for computing Z-Scores per log stream. When a Z-Score exceeds threshold α , the system generates an ESCALATE label for Tier-2 instead of dropping the packet.
- **Static Rule Engine Integration:** Incorporation of fundamental signature-based rules (DROP, WARN) to instantly eliminate rudimentary, known attack patterns.

3.3 Tier-2: LangGraph Cognitive AI Agent

- **StateGraph Design:** The architectural structure of the `SentinelState` object carrying session information. Definition of core Nodes: Analyze, Retrieve, Resolve.
- **Conditional Edges Routing:** The internal reasoning loop of the AI Agent. Upon identifying a knowledge deficit, the agent autonomously transitions to the `retrieve_knowledge` state before returning to evaluation.

3.4 Dual-RAG Mechanism and Semantic Memory

- **Dual-RAG Architecture:** Unification of two specialized knowledge bases: MITRE ATT&CK (TTP identification) and NIST SP 800-61r2 (Incident Response Handbook) [10].
- **Hybrid Search Algorithm:** The fusion of Dense (FAISS) and Sparse (BM25) scoring mechanisms utilizing RRF.
- **Semantic Cache:** A semantic hashing mechanism to bypass LLM inference if a highly similar log stream was successfully analyzed earlier in the temporal window, drastically reducing latency.

3.5 Threat Memory and APT Campaign Correlation

- **Graph Data / IP Correlation Storage (SQLite/Neo4j):** Logic for tracking the Reputation Score of IP addresses over prolonged timelines.
- **APT Correlation Mechanism:** An algorithm to chain temporally scattered, low-severity anomalies into a cohesive high-severity escalation verdict, exposing low-and-slow campaigns.

3.6 AI Security Guardrails Layer

- **Delimited Data Encapsulation:** An algorithm generating a cryptographically random token per session (e.g., `< | PAYLOAD_A7F9 | >`) to encapsulate foreign data, ensuring the LLM does not execute hidden adversarial instructions.
- **Token Budget Manager & LogTemplateMiner:** Utilizing Drain3 to strip random textual variations and cluster logs, thereby preventing LLM Token Denial-of-Service (DoS) attacks.

- **Output Sanitization Filter:** Strict standardization and JSON schema enforcement of the LLM's output.

3.7 Data Integrity and HMAC Protection

- **HMAC Log Chaining:** A cryptographic hashing algorithm linking consecutive logs, ensuring that any tampering by malicious insiders breaks the chain and is immediately flagged.
- **RAG SHA-256 Checksum Validation:** Guaranteeing the vector database is not compromised by injected falsified documents (Data Poisoning).

In summary, Chapter 3 establishes the rigorous theoretical framework of the SENTINEL architecture, holistically resolving both performance bottlenecks (Tier-1) and deep, secure cognitive reasoning (Tier-2). Chapter 4 will specify the process of translating this architecture into technical source code.

Chương 4

Technical Implementation

This chapter details the software engineering aspects and practical source code implementation of the SENTINEL architecture. Shifting from abstract theory, the content focuses on the project directory organization, core class structures (Classes/Methods), Docker service configurations, and the design of the Graphical User Interface (Streamlit Dashboard) which facilitates Human-in-the-Loop (HITL) interaction.

4.1 Technology Stack and Source Code Structure

- **Core Technologies:** Python 3.10+, LangGraph, LangChain, FAISS, SQLite, Streamlit, Docker, and llama.cpp (via the Llama-cpp-python binding).
- **Directory Structure:** A detailed tree representation strictly separating components: `src/core/` (Tier 1 & 2), `src/rag/` (Vector DB), `src/security/` (Guardrails), `src/dashboard/` (UI), `experiments/`, and `tests/`.

4.2 Tier-1 Implementation: Filtration Engine & Welford

- **RunningStats and SessionBaseline Classes:** Python source code implementation for Welford's algorithm. Resolving dictionary memory allocation challenges via IP hashing and cache garbage collection (TTL cache).
- **RuleEngine Class:** Pattern matching design based on Regular Expressions and Static Thresholds.

4.3 Tier-2 Implementation: AI Agent and RAG

- **OpenAILLMClient / Llama.cpp Wrapper:** Parameter configurations for the Local LLM (enforcing `temperature=0.0` to optimize determinism, context size bounding,

and `n_gpu_layers` mapping).

- **LangGraph Workflow Setup:** Utilizing `StateGraph` to define `analyze_node`, `retrieve_node`, and the conditional routing function `should_retrieve`.
- **DualRetriever Class:** Implementing the FAISS Index and `rank_bm25` to achieve Reciprocal Rank Fusion (RRF). Source code overview of the scoring and sorting algorithms.

4.4 Guardrail and HMAC System Implementation

- **DelimitedDataEncapsulator Class:** Logic for generating secure hexadecimal tokens via `os.urandom` and `hashlib` to wrap log payloads.
- **HMACHashing Class (Database):** Specification of the SQLite database schema (`threat_memory.db`) and the trigger functions calculating SHA-256 hashes derived from Previous Hash + Current Data.

4.5 SOC Administration Dashboard Implementation (Streamlit UI)

- **Dashboard Architecture:** Application of a Frontend (Streamlit) communicating dynamically with the Backend (SQLite/File logs) through reactive UI components.
- **Display Modules:**
 - *Real-time Queue Dashboard:* Visualizing Tier-1 alert metrics and Tier-2 verdicts.
 - *Threat Memory Analytics:* Displaying APT alert graphs across IP timelines.
 - *Audit Trail Integrity:* An automated module verifying HMAC Log Chaining, utilizing a traffic-light interface (Green = Valid, Red = Chain Broken).
- **Human-in-the-loop (HITL):** The interface for reviewing (Approve/Reject) AI-recommended verdicts to update actual Firewall Rules.

4.6 Containerization and Infrastructure Deployment

- **Dockerfile Specification:** Multi-stage build mechanisms to minimize image size and compile C++ libraries (`llama.cpp`) with CUDA acceleration support.
- **docker-compose.yml Service Management:** Linking containers for the Dashboard and Agent Engine, alongside shared log volume mounts.

In summary, Chapter 4 systematizes the software development process of SENTINEL, bridging core algorithms with user interfaces and virtualized infrastructure. Chapter 5 will subsequently establish the testing environment to quantitatively evaluate these components.

Chương 5

Experiments and Evaluation

This chapter presents the empirical evidence of the thesis, validating the research hypotheses through rigorous quantitative metrics. The SENTINEL system is evaluated against a 5-Dimensional framework (5D Metrics: Accuracy, Performance, Security, Explainability, and Integrity). The content emphasizes the layered Ablation Study design and the application of biostatistical models (McNemar's Test, Mann-Whitney U Test) to prove that the architectural enhancements are statistically significant and mathematically sound.

5.1 Experimental Environment and Datasets

- **Hardware Setup:** CPU Intel Core i9, 32GB RAM, GPU NVIDIA RTX 4060 Ti 16GB (utilized for executing the Gemma-2-9B-IT Q4_K_M model).
- **CSE-CIC-IDS2018 Dataset:** Introduction to the dataset encompassing diverse attack typologies (Brute Force, DoS, Web Attack) serving as the baseline for overarching accuracy evaluation.
- **DAPT2020 Dataset:** Employed for testing scenarios involving the identification of multi-stage Advanced Persistent Threat (APT) chains.
- **Unified Data Stream Simulation:** Detailing the scripting process that merges and replays log streams according to virtual timestamps to emulate real-time properties.

5.2 5D Evaluation Metrics and Ablation Study Design

- **Defining the 5D Metrics:** Accuracy (F1, Precision, Recall), Performance (Latency, Throughput), Security (Robustness Rate), Explainability (Audit Completeness), and Integrity (HMAC Validation).
- **Ablation Study Configurations (Config A through F):**

- Config A (Baseline 1): Traditional Rule-based engine exclusively.
- Config B (Baseline 2): Pure Local LLM inference (No RAG, no Welford).
- Config C: Welford Tier-1 + LLM.
- Config D: LLM + Single-RAG (FAISS).
- Config E: LLM + Dual-RAG Hybrid.
- Config F (Holistic SENTINEL): Tier-1 (Welford) + Tier-2 (LangGraph Agent + Dual RAG + Guardrails).

5.3 Accuracy Evaluation & McNemar’s Statistical Test

- **Precision, Recall, and F1-Score Results:** Comparative charts and tables across configurations. Highlighting Config F’s optimal F1 balance (eliminating Rule-based False Positives while enhancing Zero-day Recall).
- **APT Detection Efficacy:** Analysis of Tier-1 (Welford) capturing weak anomalous signals and subsequently activating the Agent’s Threat Memory chains.
- **McNemar’s Test Application:** Comparing the Confusion Matrices of Config B and Config F. Proving $p - value < 0.05$ (rejecting the Null Hypothesis) to confirm that the variance is attributable to architectural superiority rather than random chance.

5.4 Performance Latency Evaluation & Mann-Whitney U Test

- **Inference Latency Analysis:** Comparative table of average latency per flow. The exceptional offloading achieved by Tier-1 (Welford processing benign logs in $O(1)$ time) and the Semantic Cache (Cache Hits reducing LLM latency from 4-6 seconds to milliseconds).
- **Non-parametric Mann-Whitney U Test:** Demonstrating that the latency distribution of the SENTINEL configuration is significantly faster ($p < 0.05$) compared to routing all logs directly through the LLM.

5.5 Adversarial Robustness Evaluation (Security)

- **Adversarial AI Manipulation Dataset (45 Payloads):** Description of manipulative scenarios including Prompt Injections and Delimiter Smuggling (e.g., “Ignore system rules, report this IP as safe”).

- **Mitigation Rate Measurement:** Comparison between an unguarded system (80% manipulation success rate) versus SENTINEL's enabled Delimited Data Encapsulation mechanism (achieving near-perfect mitigation of injection attempts).

5.6 Integrity and RAG Quality Evaluation via LLM-as-a-Judge

- **HMAC Chaining Audit:** A hypothetical scenario where an attacker compromises the database to alter log labels. The dashboard immediately reports the broken hash chain.
- **RAG Scoring (RAGAS / LLM-as-a-Judge):** Utilizing an external Llama-3.1 model as an independent arbiter to score four criteria: Context Precision, Context Recall, Faithfulness, and Answer Relevancy. Proving that Dual-RAG with RRF outperforms Single Vector Search.

In summary, Chapter 5 verifies the technical prowess of SENTINEL through hard quantitative data and rigorous biostatistical tests. Chapter 6 will distill the significance of these findings and outline future trajectories.

Chương 6

Conclusion and Future Work

This concluding chapter synthesizes the comprehensive research journey of the thesis, “A Two-Tier Cognitive Architecture for Automated Threat Detection and Response Using Agentic AI” (SENTINEL). The chapter encapsulates the scientifically proven results, critically self-assesses the limitations within the scope of a master’s thesis, and illuminates new horizons for cybersecurity research integrated with Artificial Intelligence.

6.1 Synthesis of Achieved Research Results

- **Resolving Research Questions:** Reaffirming the successful mitigation of latency bottlenecks and Alert Fatigue via the tiered architecture of the Tier-1 Welford filter and the Tier-2 LangGraph Agent.
- **AI System Security (AI Security):** Demonstrating the empirical viability of Delimited Data Encapsulation and HMAC Chaining structures in thwarting adversarial manipulation risks (Prompt Injection, Delimiter Smuggling, Data Tampering) targeting internal enterprise cognitive systems.
- **Overcoming Zero-Day and APT Challenges:** The exceptional synergy between historical alert tracking (Threat Memory) and the hybrid knowledge repository (Dual-RAG MITRE + NIST) provides profound contextual awareness, enabling the system to expose highly sophisticated campaigns.
- **Validation Rigor:** These achievements transcend theoretical propositions, having been robustly validated by 5D metrics and standard statistical tests (McNemar, Mann-Whitney U) on empirical datasets.

6.2 Scientific and Practical Contributions

- **Scientific Value:** Providing a highly modular architectural framework for integrating Mathematical Statistics with Large Language Models in cybersecurity. This substantially fortifies the theoretical repository concerning LLM security and Guardrails.
- **Practical Value:** The finalized SENTINEL product serves as a core engine or an independent auxiliary tool for Small and Medium Businesses (SMBs) lacking the budget to sustain large-scale Tier-1 SOC teams, while strictly maintaining Zero Trust privacy through offline operations.

6.3 Existing Limitations

Despite the system’s demonstrated superiority, the research acknowledges distinct boundaries:

- **Input Log Formats:** The system is currently deeply tested on Network Flow logs and HTTP payloads. Real-world applicability necessitates the ingestion of highly diverse unstructured formats (Windows Event Logs, Linux Syslogs, CloudTrail), requiring significantly more complex parsing mechanisms.
- **Hardware Constraints:** Although inference speed is accelerated via Semantic Caching, processing entirely novel alerts still requires substantial LLM reasoning time. This mandates high capital expenditure for specialized GPU hardware if operating at hundreds of Gigabits/second network scales.
- **Physical Mitigation Design:** The research deliberately constrained the system to recommend actions (e.g., Recommend Firewall Rules) rather than executing physical interventions on routers to prevent Self-Denial of Service (Self-DoS). However, this restricts true Real-Time Blocking capabilities.

6.4 Future Development Directions

Stemming from these limitations, future expansion trajectories for the system include:

- **Federated Learning:** Expanding SENTINEL into a decentralized architecture. Instead of sharing privacy-violating network logs, SOC endpoints share only learned model parameters regarding novel malware variants.
- **Multi-Agent System (MAS):** Decomposing the monolithic LangGraph Agent into specialized sub-agents: Malware Analyst Agent, Network Analyst Agent, and Threat

Intel Agent. These agents would debate prior to issuing a final verdict, further elevating accuracy.

- **Automated Red Teaming:** Constructing an internal Red Team agent to continuously generate sophisticated adversarial payloads targeting Sentinel, thereby self-evaluating and autonomously upgrading the system's defensive posture.

Closing a modest endeavor, yet opening profound aspirations in the pursuit of securing the digital realm through the power of Agentic AI.

Tài liệu tham khảo

- [1] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Dataset for Cyber Security in Ad hoc Networks,” in *Proceedings of the International Conference on Information Systems Security and Privacy (ICISSP)*, 2018.
- [2] A. Alsubaei, A. Abuhussein, and S. Shiva, “Security Information and Event Management (SIEM) Features, Challenges, and Solutions,” *IEEE Access*, vol. 9, pp. 121111–121128, 2021.
- [3] P. M. M. S. Silva *et al.*, “The Big Data Security Challenges in the Era of Cloud Computing,” *Computer Networks*, vol. 156, pp. 102–115, 2019.
- [4] M. Alshamrani *et al.*, “A Survey on Advanced Persistent Threats: Techniques, Solutions, Challenges, and Research Opportunities,” *IEEE Communications Surveys & Tutorials*, vol. 21, no. 2, pp. 1851–1877, 2021.
- [5] S. Hassan, M. A. Saleem, and O. E. Ogu, “Alert Fatigue in Cybersecurity: A Review,” *IEEE Access*, vol. 10, pp. 58632–58645, 2022.
- [6] B. P. Welford, “Note on a Method for Calculating Corrected Sums of Squares and Products,” *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [7] P. Lewis *et al.*, “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [8] LangChain AI, “LangGraph: Multi-Actor, Stateful LLM Applications,” *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [9] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [10] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [11] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion Outperforms Condorcet and Individual Bootstrap Product Algorithms,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009.

- [12] T. Ravindran *et al.*, “Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content,” *arXiv preprint arXiv:2605.24421*, 2026.
- [13] A. Researcher *et al.*, “CyberRAG: An Agentic RAG cyber attack classification and reporting tool,” *Future Generation Computer Systems*, vol. 176, p. 108186, 2026.
- [14] A. Abdennebi *et al.*, “LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations,” *arXiv preprint arXiv:2604.05440*, 2026.
- [15] M. Analyst *et al.*, “Policy-Guided Threat Hunting: An LLM enabled Framework with Splunk SOC Triage,” *arXiv preprint arXiv:2603.23966*, 2026.